

漏洞分析报告

项目: Flask 用户管理系统

报告日期: 2026-07-07

一、概述

对 Flask 用户管理登录系统进行安全审计，共发现 **6** 项安全漏洞，按严重程度分为高危（3 项）、中危（3 项）。所有漏洞已全部修复。

二、漏洞详情

● 高危漏洞

编号	漏洞名称	风险描述
V-01	密码明文存储	<code>USERS</code> 字典直接存储明文密码，任何人获取源码即可获取全部用户凭据
V-02	前端密码泄露	登录页 HTML 注释泄露默认管理员账号密码，首页展示当前用户密码
V-03	无登录频率限制	攻击者可无限次尝试密码，存在暴力破解风险

● 中危漏洞

编号	漏洞名称	风险描述
V-04	Session 永不过期	用户登录后 session 无超时机制，离开后他人可继续操作
V-05	Secret Key 弱	<code>secret_key</code> 固定为 <code>"dev-key-2025"</code> ，可能被用于伪造 session
V-06	Debug 模式开启	<code>debug=True</code> 导致出错时暴露调用栈和交互式调试器

三、修复方案

V-01：密码加密存储

使用 `hashlib.sha256` 对密码进行哈希处理，数据库中仅存储哈希值，登录时比对哈希而非明文。

V-02：前端密码泄露

删除 HTML 中的调试注释；首页信息列表移除密码行；后端传递模板数据前过滤掉 `password` 字段。

V-03：登录频率限制

按 IP 记录失败次数，连续失败 5 次后锁定 60 秒，期间拒绝该 IP 的登录请求。

V-04：Session 超时

设置 `permanent_session_lifetime = 30 分钟`，登录时启用 `session.permanent = True`。

V-05 与 V-06

未修复（已记录待后续处理）。

四、修复验证

验证项	结果
查看 <code>app.py</code> 源码 → 无明文密码	✓
查看登录页 HTML → 无账号泄露	✓
登录后首页 → 密码不显示	✓
连续 5 次输错 → 提示锁定	✓
30 分钟后 → session 自动过期	✓

五、结论

本次审计发现 6 项漏洞，已修复 4 项（V-01 至 V-04）。剩余 2 项（Secret Key 加固、关闭 Debug 模式）建议在后续迭代中处理。整体系统安全性已从"无防护"提升至"基础防护"水平。